

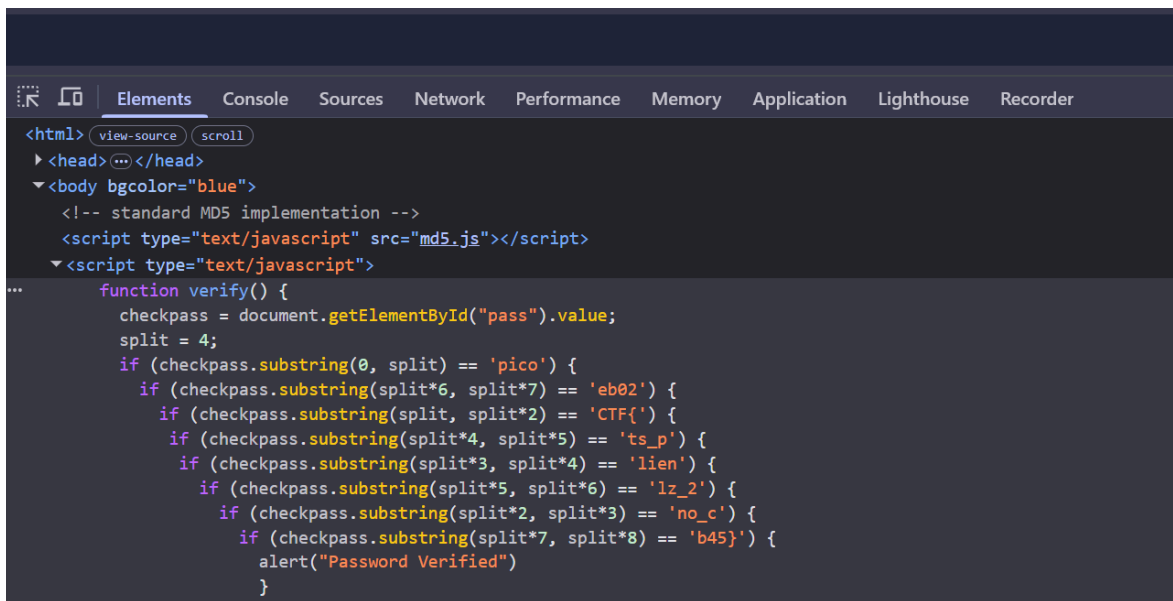
Dont-use-client-side

Kategori: Web Exploitation

Tujuan: Menemukan flag tersembunyi dengan menganalisis kode sumber dari mekanisme validasi login.

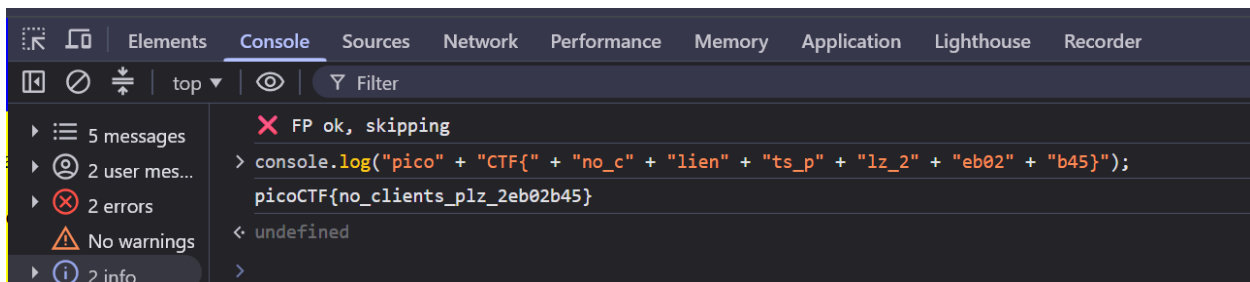
Langkah-langkah eksploitasi:

1. Membuka halaman web menampilkan formulir login sederhana. Memeriksa HTML dan JavaScript menggunakan alat pengembang peramban (F12) mengungkap skrip verifikasi sisi klien (client-side).
2. Skrip mendefinisikan fungsi `verify()` yang membaca masukan kata sandi dan memvalidasinya menggunakan beberapa pemeriksaan `substring()` berbasis variabel pengali (`split = 4`). Pengecekan kondisi `if` sengaja disusun secara acak (tidak berurutan secara kronologis) untuk mengecoh siapa pun yang membaca kodenya secara sekilas.



```
<html>
  <head>
  </head>
  <body bgcolor="blue">
    <!-- standard MDS implementation -->
    <script type="text/javascript" src="md5.js"></script>
    <script type="text/javascript">
      ...
      function verify() {
        checkpass = document.getElementById("pass").value;
        split = 4;
        if (checkpass.substring(0, split) == 'pico') {
          if (checkpass.substring(split*6, split*7) == 'eb02') {
            if (checkpass.substring(split, split*2) == 'CTF{') {
              if (checkpass.substring(split*4, split*5) == 'ts_p') {
                if (checkpass.substring(split*3, split*4) == 'lien') {
                  if (checkpass.substring(split*5, split*6) == 'lz_2') {
                    if (checkpass.substring(split*2, split*3) == 'no_c') {
                      if (checkpass.substring(split*7, split*8) == 'b45}') {
                        alert("Password Verified")
                      }
                    }
                  }
                }
              }
            }
          }
        }
      }
    </script>
  </body>
</html>
```

3. Flag dapat direkonstruksi secara manual dengan memetakan urutan indeks `split` secara kronologis dari rentang awal hingga akhir, atau secara instan dengan mengeksekusi penggabungan string langsung di tab Console browser agar nilai flag tercetak secara utuh dan siap disalin (*copy-paste*).



```
> console.log("pico" + "CTF{" + "no_c" + "lien" + "ts_p" + "lz_2" + "eb02" + "b45}");
picoCTF{no_clients_plz_2eb02b45}
< undefined
>
```

picoCTF{no_clients_plz_2eb02b45}